AZ-305 · D1 — Identity, Governance & Monitoring

WHO + visibility · rule → CA · risk → Identity Protection · score → Defender · hunt → Sentinel · AMA not MMA · 12 yrs = archive max

Entra ID SKU selection

SSO to gallery SaaS, basic MFA, security defaults → **FREE**

Conditional Access (rule-based), SSPR writeback, App Proxy, dynamic groups, Connect Health, banned-password protection → **P1**

PIM (JIT, approval, time-bound roles); Identity Protection (risk-based CA) → **P2**

Access Reviews (modern), Entitlement Mgmt, Lifecycle Workflows, PIM for Groups → **Governance**

External users / B2B / B2C → **External ID**

Confusion lock: CA = **rule-based** (you write group/location /device conditions) → P1. Identity Protection = **risk-based** (ML scores user & sign-in) → P2. PIM = elevated roles → P2. **MFA enforcement = CA Grant control.** Grant = require/block (MFA, hybrid join, compliant device, Terms of Use). Session = sign-in frequency, persistent browser, app-enforced restrictions, CAE. Risk policies only when the requirement says "risky".

Hybrid identity: auth method + sync engine

① Auth method — how users sign in

Default, simplest, leaked-credential detection → **PHS**

Password hash must stay on-prem (≥2 agents for HA) → **PTA**

AD FS-style: smart cards, on-prem MFA, custom claims → **Federation**

② Sync engine — which tool provisions

Lightweight, ≤150k objects, multi-forest / disconnected → **Cloud Sync**

Device sync (Hybrid Join), group writeback, Exchange hybrid → **Connect Sync**

PHS works with both engines. Cloud Sync = PHS only; PTA & Federation need Connect Sync. PHS is the default recommendation. **Entra DS needs NTLM/Kerberos hashes** → enable PHS even with PTA/Fed; cloud-only users reset password once after Entra DS.

Authorization (RBAC / ABAC / custom)

Built-in role fits exactly → **Built-in role**

Built-in too broad (Storage / Key Vault) → **+ ABAC condition**

Unique permission set, nothing fits → **Custom role**

Least privilege scope: Resource > Resource Group > Subscription > Management Group. Built-in always preferred over custom.

Governance tool picker

Goal	Tool
Restrict **WHAT** can be created (SKUs, regions, tags)	**Azure Policy**
Restrict **WHO** can act	**RBAC**
Control **HOW MUCH** can be spent (alerts)	**Budget / Cost Mgmt**
Prevent accidental delete/modify	**Resource Lock**
Bundle policies as a set	**Policy Initiative**
Deploy whole environment (policy+RBAC+ARM)	**Blueprints***
Manage delegated Azure subscriptions/RGs across tenants	**Azure Lighthouse**
Govern on-prem / other-cloud resources through ARM	**Azure Arc**
Share scheduled data snapshots with partner	**Data Share (D2/D5)**
Force tag inheritance RG→child	**Policy** `modify` **+ remediation**
Enforce deployment (agent, diag settings)	**Policy** `DeployIfNotExists` **+ remediation**

Trap: Policy assignment alone covers **new/updated** only — existing resources need a **remediation task**. *Blueprints deprecating → Deployment Stacks + Template Specs, but AZ-305 still answers Blueprints. Tenant boundary → Lighthouse; environment boundary → Arc; data snapshot boundary → Data Share.

Monitoring agent

Modern VM monitoring (Azure or Arc) + DCR, assign via Policy → **AMA**

MMA / OMS agent — retired Aug 2024 → **DEAD**

Log retention tiers (Log Analytics workspace)

Tier	Duration	Latency
Interactive	30 d → 2 yrs/table	Sub-sec KQL
Archive	up to **12 yrs**/table	Hours
Export to Storage	Indefinite	Manual

"Keep N yrs, occasional access" → interactive hot window + archive. **12 yrs = archive max**; longer → export to Storage.
Archive ≠ queryable: few results → **search job** (→ new table); interactive analysis of a past window → **restore** (→ temp `_RST` table).

Security posture (Defender vs Sentinel)

Score / posture / recommendations across hybrid + multi-cloud → **Defender for Cloud**

SIEM/SOAR, collect logs, KQL hunt, playbook on alert → **Sentinel**

The **verb** decides: score → Defender; hunt/respond → Sentinel. **Not this trio: Purview** = govern/classify the **data** itself (out of AZ-305 scope, DP/SC). Sentinel watches traffic · Defender scores posture · Purview inventories cargo.

Alert type picker

Trigger	Alert type
Numeric metric threshold (CPU>80%)	**Metric**
KQL query over Log Analytics	**Log**
Subscription event (create, RBAC change)	**Activity log**
Region/service health degradation	**Resource Health**
ML anomaly in App Insights	**Smart Detection**

Entra tier quick recall

- **Free:** SSO, basic MFA, security defaults
- **P1:** Conditional Access, SSPR writeback, App Proxy, dynamic groups, Connect Health
- **P2:** PIM, Identity Protection (risk-based)
- **Governance** (add-on): Access Reviews, Entitlement Mgmt, Lifecycle Workflows, PIM for Groups

JIT role activation → **always PIM** → **always P2** · Access reviews validate RBAC/group/app-role need; scheduled, user/manager attestation, auto-revoke no response; needs P2/Governance.



Identity = the new perimeter



Watch everything · alert on what matters